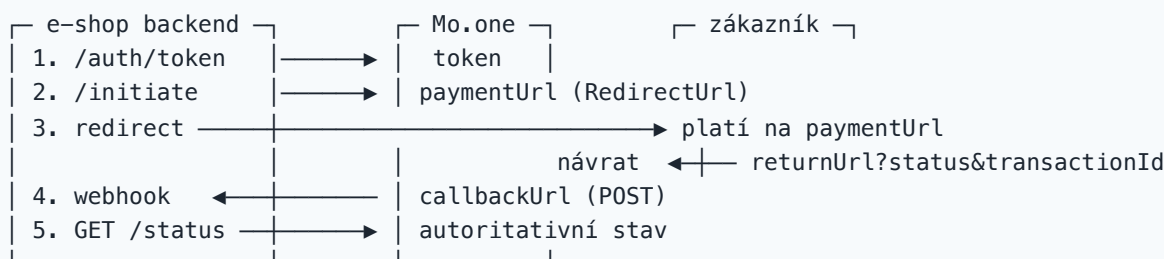


Platební brána Mo.one — integrační dokumentace

Pro vývojáře, kteří napojují e-shop na platební bránu Mo.one (redirect flow)

E-shop se autentizuje přes **OAuth2 client_credentials** (clientId/clientSecret → krátký token), založí platbu, přesměruje zákazníka na platební stránku Mo.one a po zaplacení dostane výsledek dvěma kanály: **front-channel** (návrat prohlížeče na `returnUrl`) a **back-channel** (server-to-server **webhook** na `callbackUrl`). Autoritativní stav si e-shop vždy ověří dotazem na status API.



Base URL. Test: <https://api-test.znipay.tech> · Produkce: <https://api.znipay.tech> . Všechny cesty níže jsou relativní k base URL. (Přesný host si potvrďte u Mo.one.)

Pozor na casing (klíčové!). Tři různé kanály mají tři různé konvence názvů polí:

- **REST** (token, initiate, status, cancel) → **PascalCase** (`ClientID` , `Amount` , `AccessToken` ...). Vstup je case-insensitive, ale odpovědi chodí v PascalCase.
- **Webhook** payload → **camelCase**, ale koncové „ID“ zůstává velké: `transactionPublicID` , `externalID` .
- **Návratová URL** (query) → doslovně `status` a `transactionId` .

1. Autentizace — získání tokenu

POST /payment/api/auth/token

Vymění `clientId` + `clientSecret` (z aplikace Mo.one) za krátkodobý Bearer JWT. Bez autorizační hlavičky.

Request (JSON, PascalCase):

```
{
  "ClientID": "3f2a...guid",      // veřejný identifikátor brány (GUID)
  "ClientSecret": "a1b2...64 hex" // tajný klíč (64 hex znaků)
}
```

Response 200 (PascalCase):

```
{
  "AccessToken": "eyJhbGciOi...", // JWT, token_type claim = "gateway"
  "TokenType": "Bearer",
  "ExpiresIn": 3600                // platnost 1 hodina (v sekundách)
}
```

Kód	Význam
-----	--------

403	Jednotné pro všechny případy (neznámé clientID, špatný secret, zrušené údaje, ne-gateway) — záměrně neprozrazuje, co selhalo.
429	Rate limit: max 10 požadavků / minutu / IP .

příklad

```
curl -X POST https://api.znpay.tech/payment/api/auth/token \
  -H "Content-Type: application/json" \
  -d '{"ClientID":"<guid>","ClientSecret":"<secret>"}'
```

Token směřte jednou za jeho životnost (1 h) a cachujte; není potřeba volat token endpoint před každou platbou. Token posílejte jako `Authorization: Bearer <AccessToken>`.

2. Založení platby

POST /payment/api/transactions/initiate

Vyžaduje `Authorization: Bearer <token>`. **Gateway volání neposílá `PayPointPublicID`** — platba se přiřadí bráně automaticky přes credential z tokenu.

Pole	Typ	Povinné	Popis
Amount	decimal	ano	Celková částka k úhradě. Zahrnuje spropitné (base = Amount – TipAmount).
CurrencyCode	enum (string)	ano	Např. "CZK". (Aktuálně aktivní CZK.)
ReturnUrl	string	ne*	Kam vrátit prohlížeč zákazníka. http(s), max 2048 znaků.
CallbackUrl	string	ne*	Kam poslat server-to-server webhook. http(s), max 2048.
ExternalTransactionID	GUID	ne	Vaše reference objednávky. Vrací se ve webhooku jako <code>externalID</code> .
TipAmount	decimal	ne	Spropitné obsažené v <code>Amount</code> . Default 0.
PayPointPublicID	GUID	—	Neposílat u brány (viz níže).

* `ReturnUrl` je nutné pro návrat zákazníka do e-shopu, `CallbackUrl` pro webhook — funkčně doporučené oba.

Response 200:

```
{
  "Transaction": {
    "PublicID": "UDPVPE", // veřejné ID transakce
    "Amount": 250.00, "TipAmount": 0,
    "CurrencyCode": "CZK",
    "PayPointPublicID": null,
    "RedirectUrl": "https://app.mo.one/pay/UDPVPE" // ← platební stránka
  }
}
```

`RedirectUrl` je **platební stránka** (`{web}/pay/{PublicID}`) — na ni v kroku 3 přesměrujete zákazníka.

`PublicID` použijete pro dotaz na status.

Chyby (400 / 403 / 404)

Situace	Kód
<code>Amount ≤ 0 · TipAmount < 0 · TipAmount > Amount</code>	400
<code>ReturnUrl / CallbackUrl</code> není platná http(s) URL nebo > 2048 znaků	400
Poslané <code>PayPointPublicID</code> míří na bránu („Gateway pay points cannot be targeted directly; omit payPointPublicID“)	400
Nedostupný cílový bankovní účet příjemce	404

3. Přesměrování zákazníka a návrat

3a. Přesměrujte prohlížeč zákazníka na `Transaction.RedirectUrl`. Zákazník zaplatí na hostované stránce Mo.one.

3b. Po dosažení konečného stavu je prohlížeč přesměrován zpět na vaši `ReturnUrl` s připojenými query parametry:

```
# na wire jsou tyto názvy doslovně
https://eshop.cz/navrat?status=success&transactionId=UDPVPE
```

status	Význam
success	Zaplaceno (Success)
fail	Selhalo (Fail)
cancel	Zrušeno (Cancelled) — pozor, hodnota je <code>cancel</code> , ne „cancelled“

Návrat je pouze informativní (front-channel). Neurčujte podle `status` v URL, že je objednávka zaplacená — parametr může zákazník zmanipulovat. Vždy potvrďte stav serverovým dotazem (krok 5) nebo z webhooku ověřeného přes status.

4. Webhook (server-to-server)

Mo.one pošle **POST** na `CallbackUrl` při přechodu do konečného stavu (**Success / Fail / Cancelled**), pokud byla `CallbackUrl` zadána. `Content-Type: application/json; charset=utf-8`.

Payload (JSON, **camelCase** — koncové „ID“ velké):

```
{
  "transactionPublicID": "UDPVPE",
  "externalID": "<vaše GUID reference nebo null>",
  "status": "Success",           // "Success" | "Fail" | "Cancelled"
  "amount": 250.00,
  "currencyCode": "CZK",
  "occurredAt": "2026-07-23T12:00:00Z" // UTC
}
```

- **Odpovězte 2xx.** Na non-2xx nebo síťovou chybu se doručení **opakuje** (Hangfire, až **5 pokusů** s backoffem).
- **Bez podpisu (HMAC).** Webhook je pouze notifikace — nedůvěřujte jeho obsahu naslepo. Po přijetí **ověřte stav** přes status API (krok 5).
- **Cíl musí být veřejná http(s) URL.** SSRF ochrana blokuje loopback a privátní/link-local IP adresy (10.0.0.0/8, 172.16/12, 192.168/16, 169.254/16, IPv6 ULA/link-local) a nenásleduje přesměrování (3xx). Nepoužívejte interní/lokální hosty.

5. Ověření stavu (autoritativní)

GET /payment/api/transactions/{publicID}/status

Vyžaduje `Authorization: Bearer <token>` . Vrací aktuální stav transakce.

```
{
  "PublicID": "UDPVPE",
  "PayPointPublicID": null,
  "Amount": 250.00, "TipAmount": 0,
  "CurrencyCode": "CZK",
  "Status": "Success"
}
```

404 pokud transakce neexistuje nebo k ní volající nemá přístup.

Stavy transakce (Status): `Created` , `Initiated` , `Processing` , `Success` , `Fail` , `Cancelled` , `InvestigationNeeded` . Konečné pro bránu jsou `Success` / `Fail` / `Cancelled` .

6. Zrušení platby (volitelné)

PUT /payment/api/transactions/{publicID}/cancel

Zruší dosud nezaplacenou transakci (Bearer token). Odpověď obsahuje stejná pole jako status. **404** mimo dosah volajícího.

Bezpečnostní model tokenu

- Gateway token (`token_type = gateway`) je akceptován **pouze** na `payment/api/*` . Na interním `/api/*` i na `card/api/*` je odmítnut (**403**).
- **Zrušení přístupových údajů** v aplikaci odřízne i dosud neexpirovaný token do **~10 minut** (revocation cache), nečeká se na hodinovou expiraci.
- Client secret uchovávejte jako heslo (serverové tajné proměnné). Při úniku ho v aplikaci obměňte (Client ID zůstává).

Poznámky a omezení

- **Idempotence:** posílejte vlastní `ExternalTransactionID` pro spárování objednávky; stav si držte podle `PublicID` .
- **Casing:** REST = PascalCase, webhook = camelCase, redirect query = `status / transactionId` (viz box na začátku).
- **HMAC podpis webhooků** zatím není (plánovaný follow-up) — proto vždy potvrzujte přes status API.
- Existuje i alternativní „external“ rodina endpointů (`/payment/api/transactions/external/...`) pro jiný typ integrace; pro bránu použijte výše popsaný standardní flow.